



— AXE E · LES COMPTES DE SERVICE

Le mot de passe qui ne change **jamais**

Vos comptes de service ont des mots de passe interminables — et c'est précisément pour cela qu'on peut prendre tout son temps pour les casser.

Le mot de passe de votre vieux compte de service applicatif fait trente-deux caractères. Personne ne le connaît par cœur, personne ne le change — il « marche », c'est l'essentiel. Vous le croyez inattaquable pour cette raison même. Cette fiche vous montre pourquoi un attaquant, lui, ne demande pas mieux.

■ L'IDÉE REÇUE

« Le mot de passe de ce compte de service est long et compliqué — il est inattaquable. »

En réalité — avec Kerberos, n'importe quel utilisateur du domaine peut réclamer un ticket pour ce compte, l'emporter chez lui, et tenter de casser le mot de passe **hors ligne** : sans limite de tentatives, sans verrouillage, sans la moindre alerte. La complexité ne vous protège pas — elle ne fait que rallonger le délai.

Zéro alerte, zéro verrouillage

0

Une attaque par Kerberoasting se déroule entièrement sur la machine de l'attaquant. Le domaine ne voit ni les tentatives, ni les échecs, ni le succès. La politique de verrouillage de compte n'a, ici, aucune prise.

AU SOMMAIRE DE CETTE FICHE

1**Le déclic**

L'idée reçue, l'analogie du coffre, l'impact métier.

2**Le mécanisme**

Le SPN, le ticket chiffré, le cassage hors ligne.

3**La salle des machines**

Vérifier, comprendre l'attaque, corriger et détecter.

1

NIVEAU 1 — POUR COMPRENDRE

Le déclic

Nous avons tous le même réflexe rassurant. Un compte dont le mot de passe fait trente caractères, avec majuscules, chiffres et symboles, nous semble à l'abri. Le raisonnement paraît solide : un tel mot de passe est impossible à deviner. Donc le compte est sûr.

Ce raisonnement repose sur une hypothèse cachée — et c'est elle qui cède. Il suppose que l'attaquant doit tenter ses mots de passe *contre le domaine*, une requête à la fois, sous l'œil des journaux et de la politique de verrouillage. Or il existe un cas où cette hypothèse est fausse.

Prenons une image. Un coffre-fort dans une banque est inviolable : essayez d'en forcer la combinaison sur place et l'alarme se déclenche au troisième essai. Mais imaginez que la banque vous remette, sur simple demande, une *réplique exacte* du coffre, à emporter chez vous. Plus

d'alarme, plus de gardien, plus de limite : vous pouvez essayer des combinaisons jour et nuit, pendant des mois, jusqu'à l'ouvrir.

C'est très exactement ce que permet le protocole Kerberos pour certains comptes. La banque, c'est le contrôleur de domaine. La réplique du coffre, c'est un **ticket de service** : un objet chiffré avec le mot de passe du compte. Et Kerberos remet ce ticket à n'importe quel utilisateur du domaine qui le demande, sans poser de question.

L'attaquant repart donc avec sa réplique et la travaille tranquillement, hors ligne, sur sa propre machine. La longueur du mot de passe ne change pas la nature du problème : elle ne fait qu'allonger le temps de cassage. Et le temps, dans ce scénario, l'attaquant en a à revendre.

« Un mot de passe long n'arrête pas l'attaque : il en allonge la durée. Or l'attaquant n'est pas pressé. »

POURQUOI ÇA COMPTE — L'IMPACT MÉTIER

Les comptes de service sont le maillon faible idéal, pour des raisons très humaines. Leur mot de passe est souvent fixé une fois, à l'installation, puis jamais renouvelé — le changer impliquerait de toucher à une application en production, ce que personne ne veut risquer. Ils sont fréquemment choisis par un prestataire, parfois identiques d'un client à l'autre, parfois inscrits dans une documentation. Et surtout, ces comptes sont souvent dotés de privilèges élevés « pour que ça marche ». Un attaquant qui casse l'un d'eux n'obtient donc pas un accès anodin : il hérite d'un compte puissant, dont le mot de passe ne changera pas — un point d'ancrage durable au cœur du domaine.

2

NIVEAU 2 — LE FONCTIONNEMENT RÉEL

Le mécanisme

Tout part d'un objet anodin : le **SPN**, le « Service Principal Name ». C'est l'étiquette qui désigne un service sur le réseau — par exemple `MSSQLSvc/srv-bdd.adcompagnon.lab`. Pour qu'un client puisse s'authentifier auprès d'un service via Kerberos, ce service doit porter un SPN. Et lorsqu'un SPN est rattaché à un **compte utilisateur** — le cas classique d'un compte de service applicatif — ce compte devient, sans que personne ne l'ait voulu, kerberoastable.

Voici pourquoi. Quand un client demande un ticket pour un service, le KDC le lui délivre — c'est le **ticket de service**, ou TGS. Or une partie de ce ticket est **chiffrée avec le condensat du mot de passe du compte** qui porte le SPN. C'est logique : seul le service, qui connaît son propre mot de passe, doit pouvoir l'ouvrir. Mais le KDC ne vérifie jamais que le demandeur a réellement le droit d'utiliser ce service. Il délivre le ticket à quiconque le réclame.



Schéma 1 — Le Kerberoasting : le KDC remet un ticket chiffré, que l'attaquant attaque hors ligne.

Le scénario est alors d'une simplicité déconcertante. Un attaquant, avec un simple compte du domaine, énumère les comptes porteurs d'un SPN, demande un ticket de service pour chacun, et extrait la portion chiffrée. Il dispose dès lors d'une matière à attaquer hors ligne : il essaie des millions de mots de passe par seconde sur sa propre machine, jusqu'à ce que l'un d'eux déchiffre correctement le ticket. Quand c'est le cas, il tient le mot de passe en clair du compte de service. Un facteur aggrave tout : si le ticket est chiffré en **RC4**, un algorithme ancien et faible, le cassage est bien plus rapide qu'avec de l'AES — et l'attaquant peut, dans sa demande, réclamer explicitement du RC4.

SOUS L'ÉCORCE

« Je vais imposer des mots de passe de service très longs, et le problème est réglé. » — C'est utile, mais ce n'est qu'un pansement, car cela ne fait que déplacer le curseur du temps. La vraie réponse tient en deux mots : **gMSA** — les comptes de service administrés de groupe. Un gMSA est un compte dont le mot de passe, long de 240 octets aléatoires, est **généré et renouvelé automatiquement par Active Directory**, tous les trente jours, sans intervention humaine. Personne ne le connaît, personne ne le saisit. Un ticket Kerberoasté pour un gMSA reste théoriquement cassable — mais devant 240 octets parfaitement aléatoires, le cassage hors ligne n'a plus aucun sens pratique. C'est la différence entre rendre la serrure plus dure et rendre la clé impossible à reproduire.

3 NIVEAU 3 — SUR LE TERRAIN

La salle des machines

Trois gestes, toujours dans le même ordre : **vérifier** quels comptes sont exposés, **comprendre** ce qu'un attaquant en ferait, puis **corriger et détecter**.

1 Vérifier

Commençons par le diagnostic. Cette commande liste tous les comptes utilisateurs porteurs d'un SPN — donc kerberoastables — à exécuter depuis un poste disposant du module Active Directory (RSAT).

LA COMMANDE DU JOUR — INVENTORIER LES COMPTES KERBEROASTABLES

```
PS C:\> Get-ADUser -Filter {ServicePrincipalName -like '*'} `
>> -Properties ServicePrincipalName, PasswordLastSet, msDS-SupportedEncryptionTypes |
>> Select-Object Name, PasswordLastSet, ServicePrincipalName
```

Mot à mot. Le filtre ne retient que les comptes utilisateurs dont l'attribut `ServicePrincipalName` est renseigné. La colonne `PasswordLastSet` est révélatrice : un mot de passe fixé il y a cinq ans signale un compte à traiter en priorité.

Tout compte affiché ici doit avoir un mot de passe robuste, ou mieux, être migré en GMSA.

Administrateur : Windows PowerShell

```
PS C:\> Get-ADUser -Filter {ServicePrincipalName -like '*'} ...
```

Name	PasswordLastSet	ServicePrincipalName
svc-backup	12/03/2025	AGPM/srv-gpo ...
svc-sql	04/09/2019	MSSQLSvc/srv-bdd ...
svc-web	21/01/2026	HTTP/srv-app01 ...

! La date qui parle

svc-sql porte un SPN et son mot de passe n'a pas changé depuis 2019.

Cible idéale du Kerberoasting.

Capture simulée — l'inventaire sur `adcompagnon.lab` : un compte de service au mot de passe figé depuis des années.

2 Comprendre l'attaque

Le SPN sur un compte utilisateur n'est pas une faille en soi : c'est le point d'entrée. Voici la chaîne, telle qu'un attaquant la déroule — avec un simple compte du domaine.

CE QU'UN ATTAQUANT EN FAIT

1 Le repérage

Il énumère les comptes porteurs d'un SPN — une simple requête LDAP, à la portée de n'importe quel membre du domaine. **BloodHound** les signale d'emblée comme cibles de Kerberoasting.

2 La récolte des tickets

Il demande un ticket de service pour chaque compte et en extrait la partie chiffrée — `Rubeus.exe kerberoast`, ou `impacket-GetUserSPNs`. Au passage, il réclame du chiffrement RC4, plus rapide à casser.

3 Le cassage hors ligne

De retour sur sa machine, il lance `hashcat` contre les tickets récoltés : dictionnaires, règles, des milliards d'essais. Le domaine ne voit rien — l'opération est entièrement locale.

4 Le butin

Un ticket cède : il tient le mot de passe en clair d'un compte de service — souvent privilégié, et au mot de passe figé. C'est à la fois une élévation et une persistance durable.

Le maillon de départ, c'est toujours le SPN sur un compte humain au mot de passe faible. **Supprimez l'un ou l'autre, et la chaîne casse.**

3 Corriger et détecter

La correction tient en trois gestes. Le premier supprime la cible, le deuxième prive l'attaquant de son raccourci, le troisième installe un piège.

1 Migrer vers les comptes gérés

Pour chaque compte de service porteur d'un SPN, la cible est la migration vers un **gMSA** : mot de passe de 240 octets, renouvelé automatiquement par AD. Là où c'est impossible, imposez un mot de passe d'au moins 25 caractères aléatoires.

```
● ● ● CRÉER UN COMPTE DE SERVICE GÉRÉ (GMSA)

PS C:\> New-ADServiceAccount -Name 'gmsa-sql' `
>> -DNSHostName 'srv-bdd.adcompagnon.lab' `
>> -PrincipalsAllowedToRetrieveManagedPassword 'SRV-BDD$'
```

2 Bannir le chiffrement RC4

Forcez l'AES sur les comptes de service via l'attribut `msDS-SupportedEncryptionTypes`. L'attaquant perd son raccourci : un ticket AES est nettement plus coûteux à casser qu'un ticket RC4.

3 Poser un compte-piège

Créez un compte leurre — un *honeypot* — doté d'un SPN attractif, d'aucun privilège réel, et d'un mot de passe long et aléatoire. Personne n'a de raison légitime d'en demander le ticket : toute requête le visant est, par construction, malveillante.

Détecter — le bon événement

Le Kerberoasting est furtif, mais pas invisible : la demande de ticket, elle, passe par le contrôleur de domaine et s'y journalise.

ID 4769 « Un ticket de service Kerberos a été demandé ». C'est l'événement clé. Isolément il est banal — il survient des milliers de fois par jour — mais deux signaux le rendent suspect : un **type de chiffrement** `0x17` (RC4), et un même compte qui demande en rafale des tickets pour de nombreux SPN différents.

Piège Toute occurrence de l'événement 4769 visant le **SPN de votre compte-piège** est une alerte à fiabilité maximale : aucun faux positif possible, puisque ce service n'existe pas vraiment.

Pour une **chasse proactive**, ce filtre repère les comptes de service qui acceptent encore le RC4 — les cibles les plus rentables :

```
● ● ● CHASSE — COMPTES À SPN ACCEPTANT LE RC4

PS C:\> Get-ADUser -Filter {ServicePrincipalName -like '*'} `
>> -Properties msDS-SupportedEncryptionTypes |
>> Where-Object { -not $_.'msDS-SupportedEncryptionTypes' -or `
>> ($_. 'msDS-SupportedEncryptionTypes' -band 0x4) } | Select Name
```

OBSERVATEUR D'ÉVÉNEMENTS — JOURNAL SÉCURITÉ

Event ID 4769

Compte demandeur : ADCOMPAGNON\j.martin

Nom du service : svc-sql

Type chiffrement : **0x17 (RC4-HMAC) – algorithme faible explicitement demandé**Volume : **14 SPN distincts demandés en 40 secondes****! RC4 demandé et rafale de tickets : la signature d'un Kerberoasting en cours.**

VU SUR LE TERRAIN

Lors de l'audit d'une organisation de taille moyenne, l'équipe d'attaque part d'un compte sans aucun privilège — celui d'un stagiaire fictif. En une requête, elle dresse la liste des comptes porteurs d'un SPN ; l'un d'eux retient l'attention, un compte de service applicatif dont le mot de passe, d'après l'annuaire, n'avait pas changé depuis sept ans. Le ticket récolté, le passage hors ligne n'a pris que quelques heures : le mot de passe était une variation du nom de l'éditeur du logiciel, suivie de l'année d'installation. Ce compte était membre d'un groupe d'administration. En une demi-journée, sans la moindre alerte côté domaine, le stagiaire fictif était devenu administrateur. Le correctif tenait en une migration vers un compte géré.

LE COIN DU DÉCIDEUR

Votre politique de mots de passe — longueur, complexité, verrouillage après quelques essais — protège vos comptes *humains*. Sur les comptes de service kerberoastables, elle est **sans effet** : le passage a lieu hors ligne, hors de portée de toute règle. La bonne question pour votre équipe n'est donc pas « nos mots de passe sont-ils assez complexes ? », mais « **combien de comptes de service ont encore un mot de passe géré par un humain ?** ». Chacun de ces comptes est une dette de sécurité. La cible à inscrire dans votre socle est claire : tout compte de service porteur d'un SPN doit être un compte géré, au mot de passe renouvelé par la machine.

L'ÉNIGME DU COMPAGNON — N°05

Sur `adcompagnon.lab`, le compte **a.bernard**, administrateur du domaine, n'a aucun SPN : il n'est donc pas kerberoastable, et l'équipe le sait. Pourtant, un test d'intrusion parvient à récolter un ticket de service chiffré avec son mot de passe, puis à le casser. **Comment, si a.bernard n'a pas de SPN ?**

LA RÉPONSE DU COMPAGNON

C'est le **Kerberoasting ciblé**. L'attaquant n'a pas trouvé un SPN sur a.bernard : il l'y a *ajouté lui-même*. S'il détient, sur l'objet a.bernard, un droit d'écriture sur l'attribut `servicePrincipalName` — un **GenericWrite** hérité, par exemple, comme au N°03 — il lui suffit d'inscrire un SPN arbitraire. Le compte devient instantanément kerberoastable ; l'attaquant récolte le ticket, le casse, puis efface le SPN pour ne laisser aucune trace. La protection « ce compte n'a pas de SPN » n'en est pas une si quelqu'un peut lui en greffer un. La vraie parade : verrouiller les permissions d'écriture sur les comptes Tier 0 — et donc, refermer la porte ouverte au N°03.

LE GLOSSAIRE

Compte de service — compte dédié à l'exécution d'une application ou d'un service, non à un humain.

SPN — Service Principal Name : l'étiquette qui identifie un service sur le réseau.

Kerberos — le protocole d'authentification d'Active Directory.

KDC — le composant du contrôleur de domaine qui délivre les tickets Kerberos.

TGS — ticket de service : laissez-passer pour un service, partiellement chiffré avec le mot de passe du compte.

Kerberoasting — récolte de tickets de service pour casser hors ligne le mot de passe des comptes à SPN.

Condensat — empreinte cryptographique dérivée d'un mot de passe ; ici, la clé de chiffrement du ticket.

RC4 — algorithme de chiffrement ancien et faible, qui accélère le passage hors ligne.

AES — algorithme de chiffrement moderne, bien plus résistant au passage.

gMSA — compte de service géré de groupe, au mot de passe long et renouvelé par AD.

Hashcat — outil de passage de mots de passe par essais massifs, hors ligne.

Honeypot — compte ou ressource leurre, conçu pour détecter toute interaction malveillante.

DANS LE PROCHAIN NUMÉRO



N°06 — Les relations d'approbation : la porte entre deux domaines que vous croyiez fermée

Comment la confiance accordée à un autre domaine peut devenir un couloir vers le vôtre.